Generative AI Security



© 2026 SophiArch lms.sophiarch.com

Overview of AI Security Risks

- **LLMs can leak** sensitive data or be steered into unintended actions
- **OWASP** publishes community security guidance (Open Worldwide Application Security Project)
- **Mar 2025:** LLM Top 10 project became the **OWASP GenAI Security Project**
- **Aug 2026:** new **LLM Top 10 2026** edition released, reranked using incident data

> *Agent-specific risks now have their own list: OWASP Top 10 for Agentic Applications (Dec 2025)*

© 2026 SophiArch lms.sophiarch.com

What Changed: 2025 → 2026

#	2026 Entry	2025 Rank	Change
1	**Prompt Injection**	1	—
2	**Sensitive Information Disclosure**	2	—
3	**Excessive Agency**	6	▲ largest climb, driven by tool-using apps
4	**Supply Chain**	3	▼
5	**Data and Model Poisoning**	4	▼
6	**Unbounded Consumption**	10	▲ scope widened to Denial of Wallet
7	**Misinformation**	9	▲ raised by incident data
8	**Hidden Context Exposure**	7	Renamed from System Prompt Leakage, broader scope
9	**Vector and Embedding Weaknesses**	8	▼
10	**Improper Output Handling**	5	▼ largest drop

© 2026 SophiArch lms.sophiarch.com

Watch: OWASP's Top 10 Ways to Attack LLMs

- 10-minute IBM Technology walkthrough of each risk, accessible to non-security audiences
- Uses the 2025 ranking; the risk categories are unchanged in 2026
- OWASP's Top 10 Ways to Attack LLMs: AI Vulnerabilities Exposed

© 2026 SophiArch lms.sophiarch.com

1 — Prompt Injection

- **Problem:** LLMs cannot reliably separate **instructions** from **data** in one context window
- **Direct injection:** attacker types commands, e.g. roleplay to bypass safety filters (jailbreaks)
- **Indirect injection:** instructions hidden in web pages, files, emails or images the model reads
- **Risks:** data theft, safety bypass, unauthorised tool calls

© 2026 SophiArch lms.sophiarch.com

Defending Against Prompt Injection

- **System prompt guardrails:** tell the model what not to do, a first layer and never the only one
- **AI firewall / gateway:** inspects inputs for injection patterns, filters sensitive outputs
- **Least privilege:** limit what a hijacked model can reach (see Excessive Agency)
- **Red teaming:** regularly submit crafted injections to find gaps before attackers do

© 2026 SophiArch lms.sophiarch.com

2 — Sensitive Information Disclosure

- **Issue:** models may reveal PII, PHI, credentials or confidential data in responses
- **Sources:** training data, retrieved documents, conversation history, other users' context
- **Extraction attacks:** repeated, crafted queries reconstruct training data or IP
- **Defences:** sanitise training data, redact outputs at a gateway, enforce access controls

© 2026 SophiArch lms.sophiarch.com

3 — Excessive Agency

- Giving an LLM more **functionality, permissions or autonomy** than the task needs
- A hijacked or hallucinating model can take **unauthorised real-world actions**
- **Defences:** least privilege, narrowly scoped tools, human approval for high-impact actions

© 2026 SophiArch lms.sophiarch.com

4 — Supply Chain

- **Scale:** open-source models (e.g. Hugging Face) are too large to inspect manually
- **Risk surface:** pre-trained models, LoRA adapters, datasets, plugins, libraries
- **Malicious files:** pickle-format models can run code when loaded
- **Defences:** vet suppliers, track **provenance**, scan models, prefer `safetensors`

© 2026 SophiArch lms.sophiarch.com

5 — Data and Model Poisoning

- **Attack:** manipulated pre-training, fine-tuning or embedding data plants errors, bias or backdoors
- **Impact:** degraded accuracy and safety; **backdoors** that trigger only on specific inputs
- **Defences:** strict access control on training data, data versioning, change control, anomaly checks

© 2026 SophiArch lms.sophiarch.com

6 — Unbounded Consumption

- **Denial of service:** complex or high-volume queries degrade availability
- **Denial of Wallet:** abuse drives up inference costs, no crash needed, just a bill
- **Model extraction:** mass querying to clone a model's behaviour
- **Defences:** rate limits, per-user cost caps, input size limits, usage anomaly alerts

© 2026 SophiArch lms.sophiarch.com

7 — Misinformation

- LLMs **hallucinate**: confident output that is false
- **Overreliance:** people and automated workflows act on output without checking
- **Example:** invented package names in generated code that attackers then register
- **Mitigation:** ground with RAG, human review for high-stakes decisions, user education

© 2026 SophiArch lms.sophiarch.com

8 — Hidden Context Exposure

- **Renamed** from System Prompt Leakage; covers all non-user-facing context
- **Includes:** system prompts, policy text, tool schemas, workflow rules, retrieved content
- **Assume it will leak:** never store secrets or enforce authorisation in hidden context
- **Defence:** keep credentials in a secrets manager; enforce access checks outside the model

© 2026 SophiArch lms.sophiarch.com

9 — Vector and Embedding Weaknesses

- **Poisoned documents** in RAG sources steer retrieval and override legitimate context
- **Weak access control:** retrieval returns chunks the current user shouldn't see
- **Embedding inversion:** stored vectors can be reversed to recover source text
- **Defences:** validate ingested documents, permission-aware retrieval, tenant isolation

© 2026 SophiArch lms.sophiarch.com

10 — Improper Output Handling

- LLM output passed to browsers, databases or shells without validation
- Can trigger **XSS, SQL injection, SSRF or remote code execution**
- **Defence:** treat model output as untrusted input; encode, validate and parameterise it

© 2026 SophiArch lms.sophiarch.com

References — Standards & Frameworks

Topic	Source
OWASP (2026)	OWASP GenAI Security Project. (2026). *OWASP Top 10 for LLM Applications 2026*. OWASP Foundation.
OWASP (2025)	OWASP GenAI Security Project. (2025). *OWASP Top 10 for Agentic Applications for 2026*. OWASP Foundation.
NIST (2023)	National Institute of Standards and Technology. (2023). *AI Risk Management Framework (AI RMF 1.0)*. NIST AI 100-1.
NIST (2024)	National Institute of Standards and Technology. (2024). *Generative AI Profile*. NIST AI 600-1.
Protect AI	Protect AI. (2024). *ModelScan: Protection against model serialization attacks*. GitHub.

© 2026 SophiArch lms.sophiarch.com

Summary

- LLM security spans **10 risk categories**, from prompt injection to improper output handling
- 2026 shift: **agency and cost** risks rose as models gained tools and autonomy
- No single control is enough: **defence in depth** with gateways, least privilege, validation and testing
- Design security in from the start; retrofitting is expensive and incomplete

> *The question is not whether your LLM application will be attacked, but how prepared you are*

© 2026 SophiArch lms.sophiarch.com